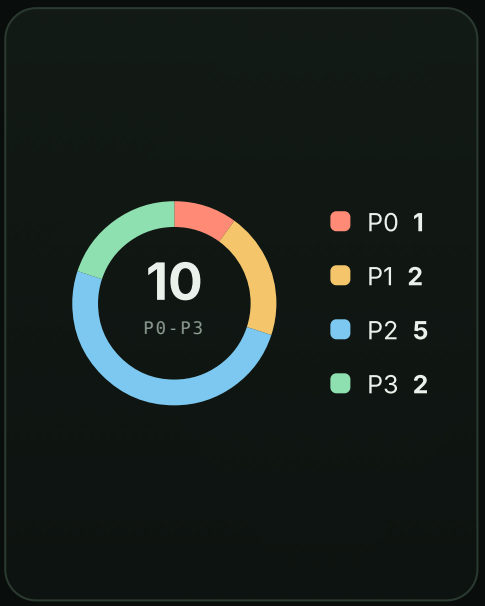
Audit: shop.example (sample data)

3 evidence sources: Known-vulnerability lookup (OSV.dev, CISA KEV) · Expert review (model judgment) · Website posture check - https://shop.example/

Act today

At least one issue is critical or actively exploited.

10 OPEN FINDINGS	**0** CONFIRMED FIXES
842 PACKAGES CHECKED	**2** IMPROVEMENT IDEAS



START HERE

The three things that matter most

P0

Table public.orders is readable by anyone: row-level security is off

ALTER TABLE public.orders ENABLE ROW LEVEL SECURITY; add a policy USING (auth.uid() = customer_id). Rollback: DISABLE ROW LEVEL SECURITY.

P1

Order lookup trusts the ID in the URL (missing ownership check)

Filter the query by the session's customer id and return 404 when it does not match.

P1

lodash 4.17.20: CVE-2021-23337

Update to 4.17.21 or later through the official channel.

WHERE THE RISK IS



FINDINGS

P0 Database expert review - model judgment `expert-review`

Table public.orders is readable by anyone: row-level security is off

WHAT COULD HAPPEN

Anyone who opens the shop can download every customer's orders and addresses with the public key shipped in the page.

WHAT WAS OBSERVED

pg_tables.rowsecurity = false for public.orders; role anon holds SELECT.

HOW TO FIX IT

ALTER TABLE public.orders ENABLE ROW LEVEL SECURITY; add a policy USING (auth.uid() = customer_id). Rollback: DISABLE ROW LEVEL SECURITY.

HOW TO VERIFY

Re-run the pg_tables query, then request the table with the public key: it must return only the caller's rows.

P1 Code expert review - model judgment `expert-review`

Order lookup trusts the ID in the URL (missing ownership check)

WHAT COULD HAPPEN

A logged-in customer can read another customer's order by changing the number in the address bar.

WHAT WAS OBSERVED

src/routes/orders.ts:42 loads the order by req.params.id without comparing it to the session user.

HOW TO FIX IT

Filter the query by the session's customer id and return 404 when it does not match.

HOW TO VERIFY

Request another account's order id: expect 404. Add a regression test.

P1 Dependencies tool evidence `dependencies`

lodash 4.17.20: CVE-2021-23337

WHAT COULD HAPPEN

Command injection through the template function.

WHAT WAS OBSERVED

Installed version is inside a published affected range. Severity high (CVSS 7.2). Known exploited: no.

HOW TO FIX IT

Update to 4.17.21 or later through the official channel.

HOW TO VERIFY

Collect a fresh inventory and re-run advisories.

P2 Dependencies tool evidence dependencies

example-http-client 1.2.0: SYNTHETIC-2026-0001

WHAT COULD HAPPEN

Synthetic example: a redirect can leak an authorization header to another host.

WHAT WAS OBSERVED

Installed version is inside a published affected range. Severity medium (CVSS 5.3). Known exploited: no.

HOW TO FIX IT

Update to 1.2.4 or later through the official channel.

HOW TO VERIFY

Collect a fresh inventory and re-run advisories.

P2 Dependencies tool evidence dependencies

example-yaml-parser 3.0.1: SYNTHETIC-2026-0002

WHAT COULD HAPPEN

Synthetic example: deeply nested input can exhaust memory.

WHAT WAS OBSERVED

Installed version is inside a published affected range. Severity medium (CVSS 5.9). Known exploited: no.

HOW TO FIX IT

Update to 3.0.5 or later through the official channel.

HOW TO VERIFY

Collect a fresh inventory and re-run advisories.

P2 Website tool evidence website

Cookie "session" is missing HttpOnly, SameSite.

WHAT WAS OBSERVED

WEB-COOKIE-001: Cookie value not recorded.

HOW TO FIX IT

Set Secure, HttpOnly and SameSite=Lax on session cookies.

HOW TO VERIFY

Re-run the website check and compare finding IDs.

P2 Website tool evidence website

No Content-Security-Policy: no browser-side limit on injected scripts.

WHAT WAS OBSERVED

WEB-CSP-001: Content-Security-Policy is absent.

HOW TO FIX IT

Start with default-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'self' in report-only mode, then enforce it.

HOW TO VERIFY

Re-run the website check and compare finding IDs.

P2 Website tool evidence website

No HSTS header: browsers may be downgraded to HTTP.

WHAT WAS OBSERVED

WEB-HSTS-001: Strict-Transport-Security is absent.

HOW TO FIX IT

Send Strict-Transport-Security: max-age=31536000; includeSubDomains once every subdomain supports HTTPS.

HOW TO VERIFY

Re-run the website check and compare finding IDs.

WORTH IMPROVING

P3 Website tool evidence website

The server header reveals software and version.

WHAT WAS OBSERVED

WEB-DISCLOSURE-001: server: nginx/1.18.0

HOW TO FIX IT

Remove or genericise the header. Then confirm the disclosed product is on a supported, patched version.

HOW TO VERIFY

Re-run the website check and compare finding IDs.

P3 Website tool evidence website

No security.txt: researchers have no clear way to report a problem.

WHAT WAS OBSERVED

WEB-SECTXT-001: /.well-known/security.txt answered 404

HOW TO FIX IT

Publish /.well-known/security.txt with a contact and expiry (RFC 9116).

HOW TO VERIFY

Re-run the website check and compare finding IDs.

IDEA Dependencies expert review - model judgment expert-review

Check dependencies automatically on every pull request

WHAT WAS OBSERVED

No dependency scan in the CI workflow.

HOW TO FIX IT

Add a lockfile scan (for example osv-scanner) to CI and fail the build on new high-severity advisories.

IDEA Website expert review - model judgment `expert-review`

Add rate limiting to login and password reset

WHAT WAS OBSERVED

No rate limit observed in the gateway configuration.

HOW TO FIX IT

Limit attempts per account and per address, and alert on bursts.

COVERAGE AND LIMITS

REPORT	EVIDENCE	DATE
`dependencies`	Known-vulnerability lookup (OSV.dev, CISA KEV)	`2026-11-10 09:12`
`expert-review`	Expert review (model judgment)	`2026-11-10 09:40`
`website`	Website posture check - https://shop.example/	`2026-11-10 09:20`

- A match means the installed version string falls in a published affected range. It does not prove the vulnerable code is reachable or exploitable here.
- No match is not proof of safety: databases lag and distributions backport fixes.
- Passive check of one URL's response headers, cookies flags and TLS handshake. It cannot see logic flaws, injection, broken access control or anything behind a login.

Read-only defensive check. Findings are signals to investigate, not a security certification. A missing finding is not proof of safety. You apply every change yourself.